

**Klarblick**

MONATSABSCHLUSS-ASSISTENT

 TECHNISCHE DOKUMENTATION

Architektur & Datenfluss

Vollständige technische Dokumentation der Klarblick-Plattform — OCR-Verarbeitung, Multi-Tenant-Architektur sowie WhatsApp- und E-Mail-Integration.

Next.js 14 App Router

Supabase + RLS

Claude Vision OCR

Twilio WhatsApp

Postmark Inbound

INHALTSVERZEICHNIS

Überblick

Alle Themen dieser technischen Dokumentation auf einen Blick.

1	Systemarchitektur Überblick über alle Komponenten und ihre Interaktion	3
2	OCR-Verarbeitung Wie Belege gescannt, erkannt und gespeichert werden	4
3	Multi-Tenant-Architektur Datentrennung, Rollen und Row Level Security	6
4	WhatsApp-Integration Twilio Webhook, Beleg-Upload und Bot-Antworten	8
5	E-Mail-Integration Postmark Inbound, Anhang-Parsing und Inbox-Flow	10
6	Datensicherheit & DSGVO Verschlüsselung, GoBD, RLS-Policies und Audit-Log	12

TECHNOLOGIE-STACK

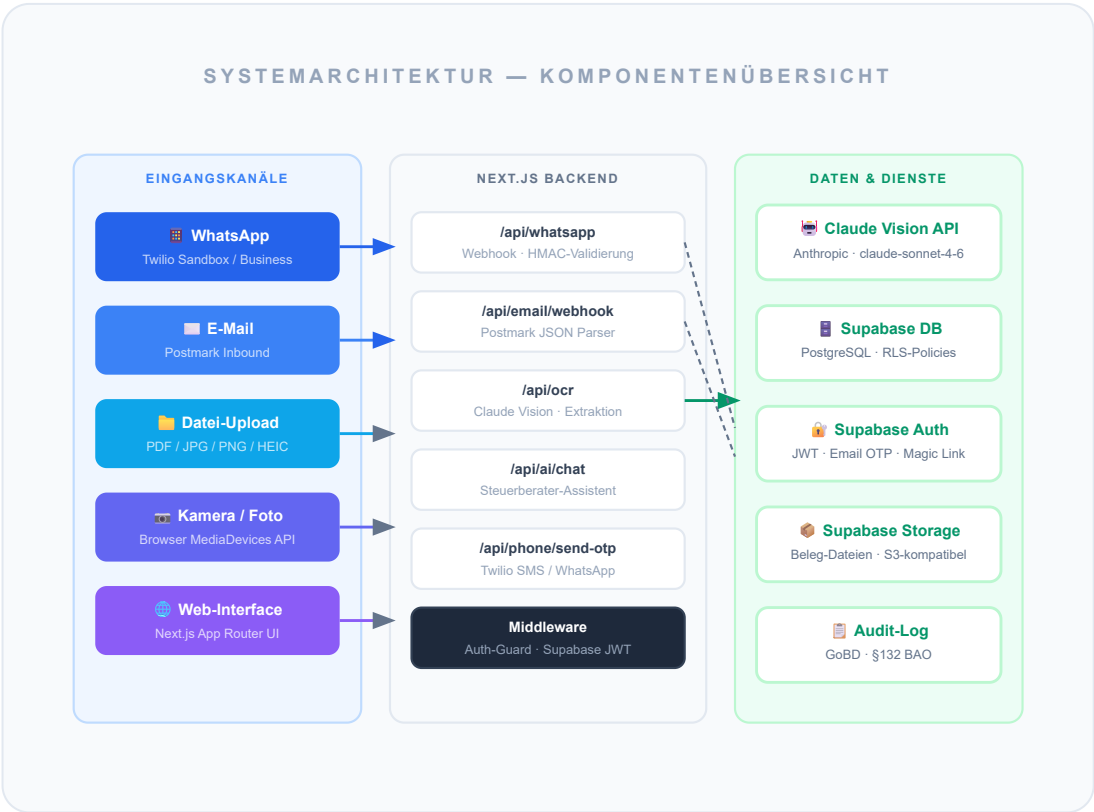
Frontend Next.js 14, React 18, Tailwind CSS	Backend Next.js API Routes, Node.js Runtime	Datenbank Supabase (PostgreSQL) + RLS
KI / OCR Anthropic Claude 3.5 Sonnet (Vision)	WhatsApp Twilio Business API + Webhook	E-Mail Postmark Inbound Parsing



01 — SYSTEMARCHITEKTUR

Gesamtüberblick

Klarblick ist eine **Multi-Tenant SaaS-Plattform** auf Basis von Next.js 14 (App Router) und Supabase. Alle Komponenten kommunizieren über definierte API-Routes — kein direkter Datenbank-Zugriff vom Frontend.



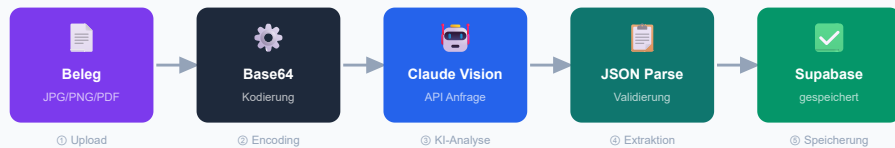


02 — OCR-VERARBEITUNG

Wie Belege gescannt werden

Klarblick nutzt **Claude Vision (claude-sonnet-4-6)** von Anthropic für die optische Zeichenerkennung. Jede Bilddatei oder PDF wird als Base64 direkt an die Claude API übergeben — ohne Drittanbieter-OCR, ohne Umwege.

OCR-VERARBEITUNGS-FLOW — SCHRITT FÜR SCHRITT



⌚ Verarbeitungszeit: 2–4 Sekunden pro Beleg

Extrahierte Felder

Claude Vision liefert ein strukturiertes JSON mit allen steuerrelevanten Feldern:

```
// Beispiel-Response von /api/ocr
{
  "vendor": "Shell Tankstelle Wien",
  "date": "2026-06-12",
  "gross_amount": 87.40,
  "net_amount": 72.83,
  "vat_amount": 14.57,
  "vat_rate": 20,
  "currency": "EUR",
  "invoice_type": "eingang",
  "category": "Treibstoff/KFZ",
  "receipt_type": "Tankbeleg",
  "warnings": []
}
```

AT Österreich-spezifisch

Claude wird explizit mit AT-UStG 1994 instruiert: 20%/13%/10% MwSt-Sätze, Reverse Charge §19, Vorsteuerauschluss §12 (PKW vs. Kastenwagen), ATU-Nummer-Matching.

⚠ Unsichere Belege

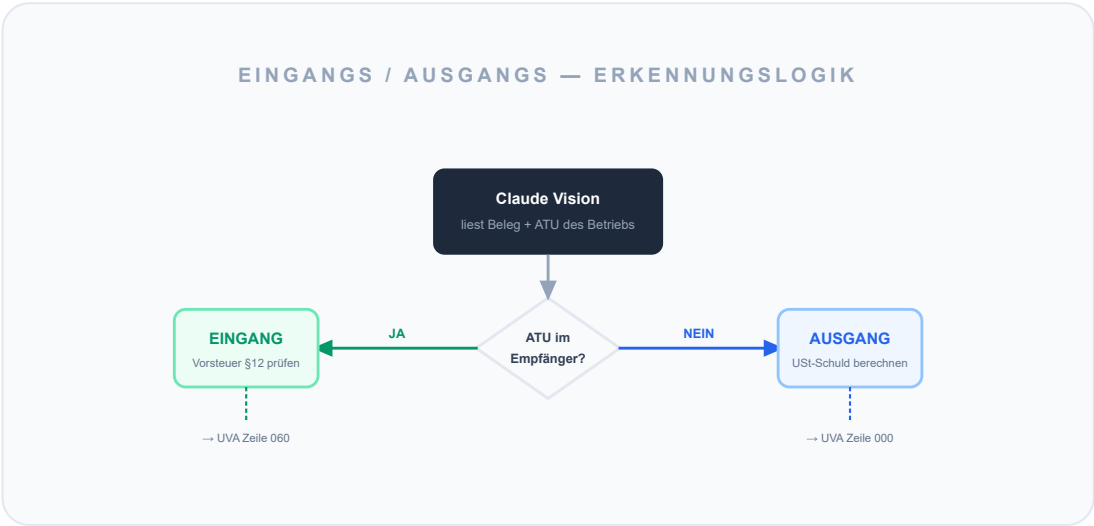
Wenn Claude unsicher ist (unlesbare Schrift, fehlende Felder, ungewöhnliche Beträge), setzt es Einträge im

`warnings`-Array. Der Beleg wird als

`unsicher` markiert.

Eingangs- vs. Ausgangsrechnung — automatische Erkennung

Klarblick erkennt automatisch ob ein Beleg eine **Eingangsrechnung** (Lieferant → Betrieb) oder eine **Ausgangsrechnung** (Betrieb → Kunde) ist. Dazu wird die ATU-Nummer des Unternehmens an Claude übergeben:



Confidence Score & Warnings

STATUS	BEDINGUNG	DARSTELLUNG IN APP
✓ geprüft	Alle Pflichtfelder vorhanden, keine Warnungen	Grüner Punkt, sofort verwendbar
⚠ unsicher	Claude hat Warnungen gesetzt (unleserlich, fehlende Felder)	Gelber Punkt, manuelle Prüfung nötig
✗ fehlgeschlagen	Kein JSON extrahierbar (kein Beleg, Foto zu unscharf)	Roter Punkt, manuell erfassen

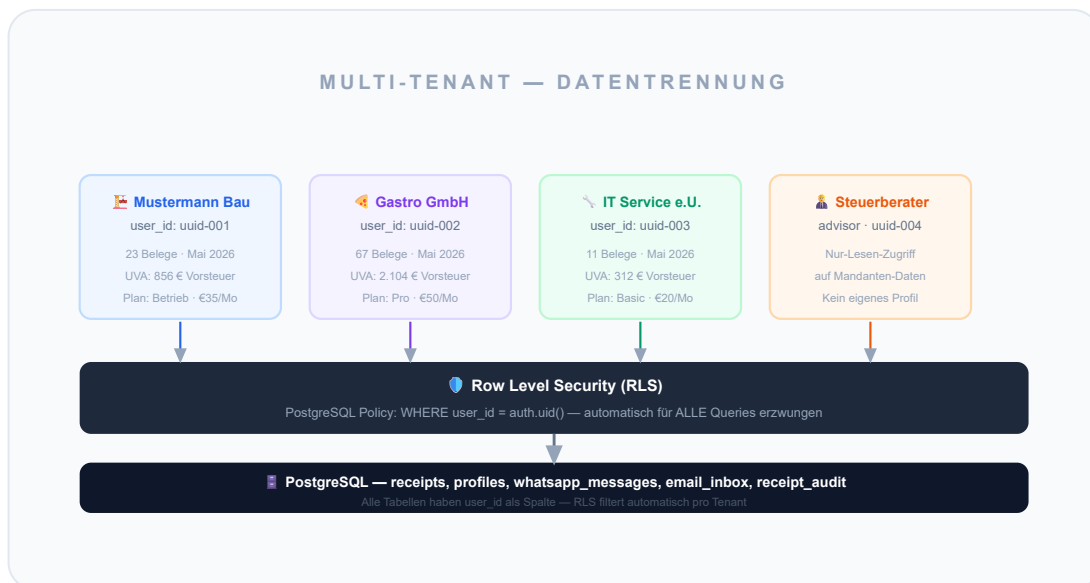
💡 **Datenschutz:** Beleg-Bilder werden ausschließlich für den OCR-Aufruf an Anthropic übermittelt. Anthropic speichert keine Bilder über den API-Call hinaus (Anthropic API Data Privacy). Die extrahierten Textdaten (Betrag, Lieferant, Datum) liegen ausschließlich in der EU-gehosteten Supabase-Instanz.



03 — MULTI-TENANT

Datentrennung & Rollen

Klarblick ist eine **Multi-Tenant-Plattform** — jeder Betrieb (Tenant) sieht ausschließlich seine eigenen Daten. Die Trennung erfolgt auf Datenbankebene über **Row Level Security (RLS)** in Supabase/PostgreSQL. Kein Code im Frontend entscheidet über Datenzugriff.



Rollensystem

Klarblick kennt vier Rollen mit klar definierten Berechtigungen:

ROLLE	BESCHREIBUNG	BEARBEITEN	LÖSCHEN	ÜBERGABE	TEAM	EXPORT
sw_admin	System-Administrator (Amin Sistik)	✓	✓	✓	✓	✓
owner	Firmeninhaber — voller Zugriff auf eigenen Tenant	✓	✓	✓	✓	✓
member	Mitarbeiter — Belege erfassen & prüfen	✓	✗	✗	✗	✓
advisor	Steuerberater — ausschließlich Lesezugriff	✗	✗	✗	✗	✓

Plan-Abgrenzung (Tarif-Gating)

Zusätzlich zur Rolle bestimmt der **Abo-Plan** welche Features nutzbar sind:

 **Basic · €20/Mo**

Dashboard ·
Sammelstelle
Belegliste ·
Einstellungen
Bis 30 Belege/Monat

 **Betrieb · €35/Mo**

+ Beleg-Check (Inbox)
+ Auswertung · UVA ·
Übergabe
+ WhatsApp & E-Mail-
Eingang
Bis 100 Belege/Monat

 **Pro · €50/Mo**

+ KI Pro-Analyse
+ Steuerfälle
+ Rollen & Team
Unbegrenzte Belege

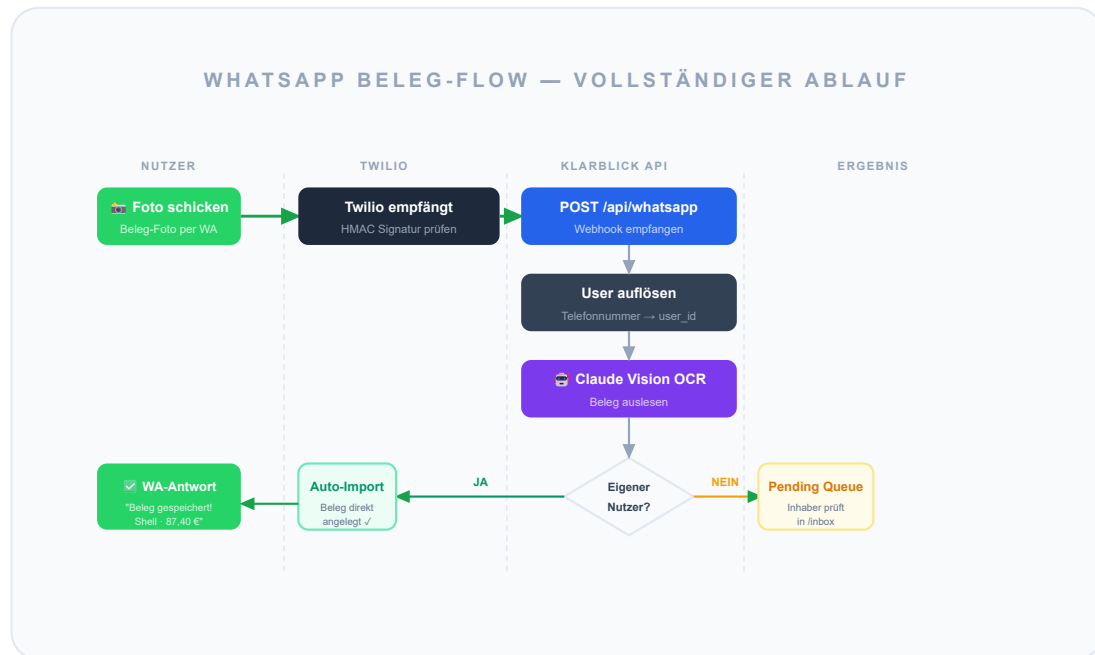
Technische Umsetzung: Der Plan wird als `user_metadata.plan` im Supabase JWT gespeichert. Beim Login liest die App diesen Wert und cached ihn in `localStorage`. Die Sidebar zeigt gesperrte Features mit einem Schloss-Icon — ein Klick darauf zeigt eine Info-Toast mit dem benötigten Plan.



04 — WHATSAPP-INTEGRATION

Beleg-Upload per Foto

Nutzer senden Belege per Foto an die Klarblick-WhatsApp-Nummer. Twilio empfängt die Nachricht, ruft den Webhook auf, Klarblick liest das Bild per OCR aus und legt automatisch einen Beleg an — ohne dass der Nutzer die App öffnen muss.



Sicherheit — HMAC Validierung

Jeder Twilio-Webhook wird via HMAC-SHA1 Signatur verifiziert. Der `TWILIO_AUTH_TOKEN` signiert alle Parameter — gefälschte Requests werden mit HTTP 403 abgelehnt.

Kollegen-Belege

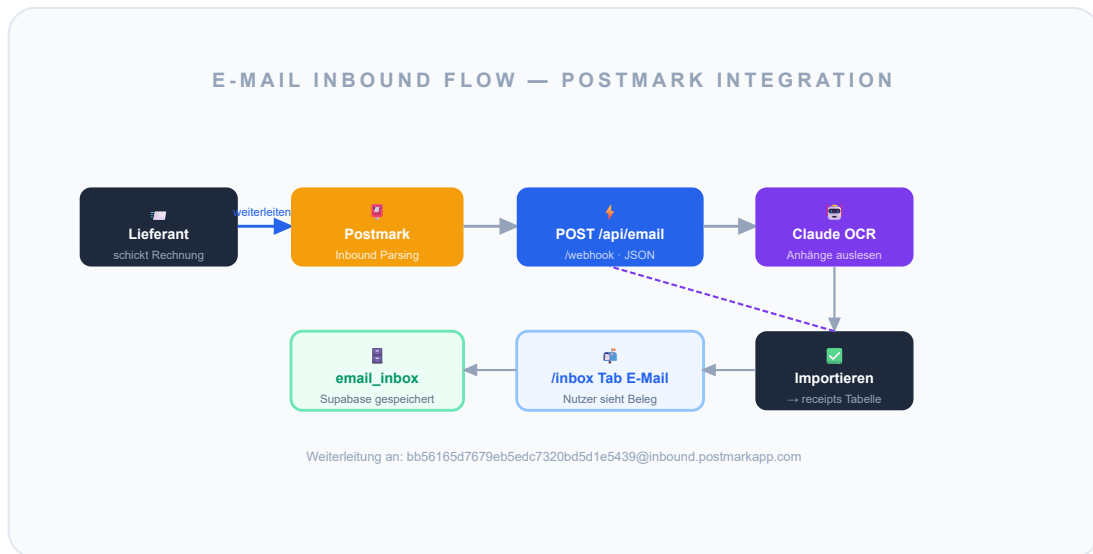
Mitarbeiter die die Sandbox-Nummer gejoined haben, senden Belege an den Inhaber-Account. Unbekannte Nummern bekommen eine Registrierungs-Aufforderung zurück.



05 — E-MAIL-INTEGRATION

Rechnungen per E-Mail

Nutzer leiten Rechnungs-E-Mails an ihre persönliche Klarblick-Adresse weiter. Postmark verarbeitet den Eingang, extrahiert Anhänge und sendet alles als JSON an den Webhook. Klarblick führt OCR auf den Anhängen durch und speichert die Ergebnisse.



Webhook-Payload von Postmark

Postmark sendet ein JSON-Objekt mit allen E-Mail-Metadaten und Anhängen (Base64-kodiert):

```
// POST /api/email/webhook - Postmark JSON
{
  "From":      "rechnungen@lieferant.at",
  "To":        "bb56165d@inbound.postmarkapp.com",
  "Subject":   "Ihre Rechnung Nr. 2026-1842",
  "Date":      "2026-06-14T10:23:00Z",
  "Attachments": [{
    "Name":     "rechnung-1842.pdf",
    "ContentType": "application/pdf",
    "Content":   "JVBERi0xLjQK..." // Base64
  }]
}
```




06 — DATENSICHERHEIT & DSGVO

Compliance & Datenschutz

EU EU-Hosting & DSGVO

Alle Daten liegen in der EU (Frankfurt, AWS eu-central-1 via Supabase). Kein Drittland-Transfer personenbezogener Daten. AV-Vertrag mit Supabase verfügbar.

Verschlüsselung

TLS 1.3 für alle API-Verbindungen. Supabase verschlüsselt Daten at-rest (AES-256). Auth-Tokens werden nie im Klartext gespeichert.

GoBD & §132 BAO

Jede Änderung an einem Beleg erzeugt einen Eintrag im `receipt_audit` -Log (action, field, before_value, after_value, timestamp). Unveränderlich, nicht löschar.

Row Level Security

PostgreSQL RLS-Policies erzwingen Mandantentrennung auf Datenbankebene — nicht im Applikationscode. Selbst ein Bug im Backend-Code kann keine fremden Daten preisgeben.

API-Schlüssel-Verwaltung

Alle Credentials liegen als Env-Variablen — niemals im Code. `SUPABASE_SERVICE_ROLE_KEY` und `TWILIO_AUTH_TOKEN` sind ausschließlich serverseitig verfügbar.

WhatsApp Datenschutz

Twilio Media URLs laufen ab. Bild-Daten werden nur für den OCR-Aufruf verwendet und nicht dauerhaft gespeichert. In `whatsapp_messages` wird nur die Media-URL, nicht das Bild selbst gespeichert.

Audit-Log Struktur (GoBD)

FELD	TYP	BESCHREIBUNG
<code>receipt_id</code>	uuid	Referenz auf den Beleg
<code>user_id</code>	uuid	Wer hat die Änderung gemacht
<code>ts</code>	timestampz	Zeitpunkt der Änderung (UTC)

FELD	TYP	BESCHREIBUNG
<code>action</code>	enum	created · updated · deleted · status_change
<code>field</code>	text	Welches Feld geändert wurde
<code>before_value</code>	text	Wert vor der Änderung
<code>after_value</code>	text	Wert nach der Änderung

⚠ **Wichtiger Hinweis:** Klarblick ist ein Vorbereitungs-Tool, kein Ersatz für Steuerberatung. Die finale Prüfung und Einreichung von UVA und Jahresabschluss obliegt dem Steuerberater des Unternehmens. OCR-Ergebnisse sollten vom Nutzer auf Richtigkeit geprüft werden.

Klarblick GmbH

Wienerbergstraße 11 · 1100 Wien · cohub Coworking · 16. Stock

amin.sistek20@gmail.com · app.klarblick.at

Technische Dokumentation v1.0 · Juni 2026 · Vertraulich — nur für interne und Pilot-Zwecke